ECPFL 论文审稿意见

论文标题: ECPFL: Efficient Ciphertext Prefetching for Secure Cross-Device Federated Learning
审稿日期: 2026-07-01
审稿重点: 威胁模型（Threat Model）、安全目标（Security Goals）、安全性分析（Security Analysis）三模块的衔接与规范性；并与 ESAFL [33] 的安全分析框架进行对照。

一、总体评价

本文提出了一种面向跨设备联邦学习的密文预取框架 ECPFL，通过 Efficient Sparse Packing（ESP）和 Efficient Ciphertext Prefetching（ECP）两个机制，试图在上行稀疏化与下行预取之间实现隐私与通信效率的联合优化。实验部分涵盖了四个数据集，并与 FedAvg+CKKS、FedPHE、ESAFL、MASER 等基线进行了对比，工作量较大。

然而，论文在**威胁模型、安全目标与安全性分析**三个核心模块上存在明显的衔接不畅、概念混淆和证明不严谨的问题，具体表现为：

1. **威胁模型表述不规范**：“hybrid threat model”一词使用不当，实际仍是标准的 honest-but-curious（半诚实）模型；KGC 的强信任假设与所声称的“半诚实”设置不一致。
2. **安全目标与威胁模型不对应**：安全目标抽象为“数据保密性、抗合谋、跨轮隐私”，但未明确映射到各参与方（KGC、Server、Client、外部窃听者）的能力边界；且对投票掩码、客户端选择等明文泄露未作说明。
3. **安全性分析存在逻辑漏洞**：Theorem 3 与正文的“(N-1)-resilience”表述自相矛盾；Theorem 5 的“one-time pad”论证不成立；Theorem 4 关于 dropout 隐私的结论与 Server 本身即选择活跃/非活跃客户端的事实相悖。
4. **对 ESAFL 分析的借鉴流于表面**：虽然在方案构造上参考了 ESAFL 的多密钥 RLWE 加密与一步解密，但安全证明未能沿用 ESAFL 的严谨形式（分布不可区分、spanning-rounds 聚合等），且关键假设（KGC 知道所有私钥、存在安全信道）与 ESAFL 的“无安全信道”假设形成冲突。

以下按模块分条列出具体问题与修改建议。

二、威胁模型（Threat Model）模块问题

M1.1 “hybrid threat model”术语使用不当

- **位置**：第 IV-B 节，第 6 页，第 475–487 行。

- **问题描述：**论文称“We formalize ECPFL under a hybrid threat model, establishing a rigorous cryptographic baseline… The system comprises a fully trusted coordinator and honest-but-curious participants.”但后文对 KGC、Server、Client 的描述实际上对应的是经典的 **honest-but-curious（半诚实）模型**加上一个可信第三方 KGC，并非密码学文献中通常所说的“hybrid model”（hybrid model 一般指理想/现实混合模型，或主动/被动混合敌手）。
- **与 ESAFL 对比：**ESAFL 第 III-A 节明确使用“honest-but-curious”描述 clients 和 cloud server，并用“trusted entity”描述 AS，术语规范、一致。
- **修改建议：**删除“hybrid”一词，改为“standard semi-honest (honest-but-curious) threat model with a trusted key-generation center”。若确实要强调 KGC 与参与方的不同信任级别，可用“two-tier trust model”或“(trusted KGC, semi-honest server/clients)”表述。

M1.2 KGC 的信任假设过强且与实验设置冲突

- **位置：**第 IV-B 节；Algorithm 1 第 2–3 行；Algorithm 2 第 15–17 行。
- **问题描述：**
  - KGC 被定义为“fully trusted”，负责生成所有加密密钥 {s_i}、全局解密密钥 S，并通过安全信道分发给客户端。
  - 更重要的是，KGC 在每一轮为每个非活跃客户端 k ∈ S(t) 生成 compensatory ciphertext，这需要 KGC 掌握每个客户端的私钥 s_k（或能代表其生成密文）。
  - 在半诚实威胁模型下，KGC 一旦不可信或被攻破，所有客户端隐私将完全泄露；而论文实验却声称在半诚实模型下进行，二者存在张力。
- **与 ESAFL 对比：**ESAFL 的 AS 仅在初始化阶段生成并分发密钥，后续不参与训练/聚合，也不持有客户端私钥用于生成补偿密文。ECPFL 让 KGC 持续参与每一轮并掌握全部私钥，是一个更强的信任假设，但论文未明确讨论其影响。
- **修改建议：**
  1. 在威胁模型中明确列出 KGC 的权限：它不仅生成密钥，还持续为 dropout 客户端生成补偿密文，因此必须持有所有 s_k。
  2. 讨论该假设与 cross-device 场景的兼容性：cross-device 中客户端数量大、不可信度高，集中式 KGC 掌握全部私钥是重大单点故障。
  3. 若坚持该设计，建议在安全目标中增加“KGC compromise resistance”或明确声明不抵抗 KGC 与 Server 合谋。

M1.3 未明确 KGC 与 Server 之间的通信假设

- **位置：**第 IV-B 节；Fig. 2；Algorithm 2 第 15–17 行。
- **问题描述：**KGC 需要知道每轮的非活跃客户端集合 S(t) 和共识集合 K(t)，才能生成补偿密文。这一信息由谁提供？KGC 与 Server 之间是否安全？论文仅在 Fig. 2 标注了“red line = secure channel, blue line = insecure channel”，但未明确 KGC-Server 信道属于哪一类。

- **修改建议**：在威胁模型中明确 KGC-Server 信道假设（安全/不安全），并在算法或系统模型图中标注 KGC 接收 S(t) 和 K(t) 的交互。

M1.4 未区分“外部窃听者”与“内部半诚实敌手”

- **位置**：第 IV-B 节。
- **问题描述**：ESAFL 明确将外部窃听者（eavesdroppers on public channels）纳入威胁模型，并指出其能力与 cloud server 相同，因此只需分析 server 和 clients。ECPFL 的威胁模型只列出 KGC、Server、Clients，未提及外部窃听者，但论文又在 Theorem 5 中提到“conceals intermediate states from eavesdroppers”。
- **修改建议**：在威胁模型中显式定义外部被动窃听者 E，并说明其观测能力（可见 Server-Client 公共信道上的所有密文、投票掩码等）。

M1.5 半诚实模型下未讨论完整性（Integrity）边界

- **位置**：第 IV-B 节。
- **问题描述**：ECP 模块依赖 Server 维护滑动队列 Q_j 并执行跨轮聚合。在半诚实模型中，Server 不会主动篡改，但可能通过延迟、重排、选择性转发来影响训练。论文未说明安全分析是否覆盖可用性/正确性，还是仅覆盖隐私。
- **修改建议**：明确声明安全目标仅限于 **privacy（IND-CPA 语义安全）**，不保证 integrity/availability；或补充对 Server 行为一致性的讨论。

三、安全目标（Security Goals）模块问题

M2.1 安全目标与威胁模型实体映射不清晰

- **位置**：第 IV-B 节第 2）小节，第 7 页，第 552–571 行。
- **问题描述**：论文将安全目标概括为 (1) Data Confidentiality, (2) Collusion Resistance, (3) Cross-Round Privacy。但这三条目标未明确对应到具体敌手：
  - Data Confidentiality 主要防 Server 和外部窃听者；
  - Collusion Resistance 主要防 N-2 个恶意客户端与 Server 合谋；
  - Cross-Round Privacy 涉及多个授权客户端跨轮观测。这种抽象表述让读者难以判断每条定理究竟保护了谁不受谁攻击。
- **与 ESAFL 对比**：ESAFL 第 III-B 节的设计目标简洁明确：“clients’ private dataset should keep hidden from the other clients and the public cloud server; the aggregation results should be secret to the cloud server.”直接对应威胁模型中的 entities。

- **修改建议**：采用表格形式，将三条安全目标与威胁模型中的 KGC、Server、Clients、Eavesdropper 一一映射，并说明每条目标所依赖的假设（如 KGC 可信、无 KGC-Server 合谋等）。

M2.2 “任何 Server 观测都计算不可区分于均匀随机”过于绝对

- **位置**：第 IV-B 节第 2）小节，第 555–559 行。
- **问题描述**：论文称“Any observation available to the server must be computationally indistinguishable from uniform randomness, preventing the inference of individual or aggregated model parameters during standard protocol execution.”但 Server 实际能观测到：
  - 明文投票掩码 v_i(t)；
  - 哪些客户端被选中（S(t)）、哪些是非活跃（S(t)）、哪些被预采样（P(t*)）；
  - 每轮上传的密文数量（反映 K(t) 的大小）。这些观测显然不是均匀随机的，且可能泄露客户端梯度分布的部分信息。
- **修改建议**：将表述改为“Server’s observation of ciphertexts is computationally indistinguishable from random RLWE samples, while the plaintext vote masks and client selection metadata are explicitly revealed.”并在威胁模型/安全目标中承认这些泄露，或增加对 vote mask 隐私影响的分析。

M2.3 未将“投票掩码泄露”纳入安全目标

- **位置**：第 IV-C 节；Fig. 3。
- **问题描述**：ESP 协议中，每个活跃客户端将其 Top-k 投票掩码 v_i(t) 以明文发送给 Server。Server 由此可知每个客户端认为哪些 pack 更重要。在 Non-IID 场景下，这种掩码模式可能与客户端数据分布相关，构成侧信道信息。
- **与 ESAFL 对比**：ESAFL 不涉及客户端向 Server 发送明文选择掩码，所有梯度均加密上传，不存在此类泄露。
- **修改建议**：
  1. 在安全目标中增加一条“Vote Pattern Privacy”或明确声明不保护投票模式。
  2. 若声称保护，则需设计隐私保护投票机制（如差分隐私掩码、安全聚合投票等）并给出证明。

M2.4 安全目标未覆盖“dropout 隐私”的合理定义

- **位置**：第 IV-B 节；Theorem 4。
- **问题描述**：论文提出“dropout privacy”并称 Server 无法从补偿密文推断客户端是否在线。但如前所述，Server 本身选择 S(t) 和 S(t)，因此 dropout 状态对 Server 而言是已知的。该安全目标定义不清。
- **修改建议**：明确 dropout 隐私的保护对象。若目标是防外部窃听者（而非 Server），则应改为“External eavesdroppers cannot distinguish a compensatory ciphertext from an active client’s ciphertext, hence cannot infer client participation.”

四、安全性分析（Security Analysis）模块问题

M3.1 Theorem 3 与正文“(N-1)-resilience”自相矛盾

- **位置**：第 IV-B 节末尾（第 6 页末-第 7 页初）；第 V 节 Theorem 3（第 10 页，第 780-805 行）。
- **问题描述**：
  - 正文称“we assume a strict (N − 1)-resilience model: up to N − 1 corrupted clients may pool their private key shares and observed transcripts to target the remaining honest client.”
  - 但 Theorem 3 标题为“(N − 2)-collusion resistance”，证明中讨论的是“If N − 1 clients collude… individual plaintexts remain strictly unrecoverable”。
  - 概念混淆：若允许 N−1 个客户端合谋，则仅剩 1 个诚实客户端；此时这 N−1 个客户端加上 Server 可重构 S 并得到聚合结果，但无法解出诚实客户端的单独明文——这正是 **(N-2)-collusion resistance**（即最多容忍 N−2 个客户端合谋）的通常含义。论文将“(N-1)-resilience”与“(N-2)-collusion resistance”混用，容易误导读者。
- **与 ESAFL 对比**：ESAFL Theorem 5 明确表述为“ESHE is secure against collusion attacks of κ < N − 1 clients”，即最多 N−2 个合谋客户端，术语一致。
- **修改建议**：统一使用标准术语。建议正文改为“(N-2)-collusion resistance”或“tolerating up to N-2 corrupted clients”，与 Theorem 3 保持一致。若确实想表达 N−1 合谋时聚合结果仍对 Server 保密，则应说明那是“aggregate result secrecy against server”而非“collusion resistance”。

M3.2 Theorem 5 “one-time pad”论证不成立

- **位置**：第 V 节 Theorem 5，第 9-10 页，第 721-786 行。
- **问题描述**：论文称跨轮预取密文解密后，授权客户端得到 m_pre,j = ∑_{r=0}^{R-1} m_j(t+r)，并断言“Since m_pre,j is the sum of R independent plaintext variables, the conditional distribution of any intermediate update m_j(t+r) is uniform in R_p, effectively acting as a one-time pad that renders historical single-round states unconditionally hidden.”该结论错误：
  - 已知和 m_pre,j 后，单个加数 m_j(t+r) 的分布并非均匀分布，而是受和约束的条件分布。
  - 除非每个中间 plaintext 都额外叠加了独立的均匀随机 one-time pad，否则无法得到“unconditionally hidden”结论。
  - 进一步地，这些 plaintext 是模型梯度更新，本身具有强相关性，并非独立均匀随机变量。
- **与 ESAFL 对比**：ESAFL Theorem 2 讨论的是 **spanning-rounds aggregation ciphertext** 的分布与均匀分布不可区分（multi-round privacy of ciphertexts），而不是解密后单个 plaintext 对授权客户端隐藏。ESAFL 的结论更弱但更合理。
- **修改建议**：
  1. 删除“one-time pad”和“unconditionally hidden”等不准确表述。

2. 将 Theorem 5 重新表述为 ciphertext-level 的隐私：跨轮聚合密文 C_pre,j 与均匀随机元组 (A_pre, u) 在 dRLWE 假设下计算不可区分，从而保护中间状态不被被动窃听者获取。
3. 若需对授权客户端的视图做分析，应说明授权客户端合法解密后获得的是 R 轮聚合结果，无法直接分离单轮贡献，但这只是“功能性不可逆”，并非信息论安全。

M3.3 Theorem 4 关于 dropout 隐私的结论与事实矛盾

- **位置**：第 V 节 Theorem 4，第 9–10 页，第 809–831 行。
- **问题描述**：Theorem 4 称“the server cannot infer the dropout status of any participant”，因为补偿密文与有效客户端密文不可区分。但：
  - Server 在 Algorithm 1 第 8 行主动选择 S(t)、$\bar{S}$(t)、P(t*)；
  - Algorithm 2 第 15–17 行明确说明 KGC 为非活跃客户端生成补偿密文；
  - Server 接收并执行 ESP-AGG 时，知道哪些 ct_{i,j} 来自活跃客户端、哪些 ct_{k,j} 来自 KGC 补偿。因此，Server 完全掌握每个客户端的参与状态。
- **修改建议**：
  1. 将 Theorem 4 的保护对象改为 **外部被动窃听者**（external eavesdroppers），他们无法区分补偿密文与真实客户端密文。
  2. 或重新定义该定理为“Compensatory ciphertexts are computationally indistinguishable from valid client ciphertexts under the dRLWE assumption”，而不附加“Server cannot infer dropout status”的结论。

M3.4 Theorem 2 “Server Obliviousness”证明粒度不足

- **位置**：第 V 节 Theorem 2，第 10 页，第 760–774 行。
- **问题描述**：
  - 证明仅说明 Server 看到单个密文 c_{i,j}^{(t)} = [a(t)s_i + …] 时，其掩码部分在 dRLWE 下伪随机。
  - 但未说明 Server 看到多个客户端、多轮密文时的联合分布；未考虑 compensatory ciphertexts 的引入；未考虑 a(t) 由 PRPG 生成带来的潜在相关性。
  - “obtain individual gradients pt_{i,j}^{(t)} or the aggregate m_j(t)”的表述中，Server 实际上可以计算聚合密文 C_j(t)，只是无法解密。应区分“observe aggregated ciphertext”与“learn aggregated plaintext”。
- **修改建议**：
  1. 将证明形式化：定义 Server 的视图 View_S，包括所有活跃客户端密文、补偿密文、投票掩码、队列内容，证明其与适当分布不可区分。
  2. 明确 Server 无法获得的是 **明文梯度/聚合结果**，而非密文聚合本身。

M3.5 Theorem 1 IND-CPA 证明缺少多密钥形式化

- **位置**：第 V 节 Theorem 1，第 9–10 页，第 722–756 行。
- **问题描述**：
  - 证明采用标准单挑战 IND-CPA 游戏，Challenger 生成 (s_i, a(t))，adversary 提交 m_0, m_1，Challenger 返回 c* = [a(t)s_i + p~e + m_b]_q。
  - 但未说明挑战的是哪个客户端的哪个密钥；在多密钥设置下，不同客户端的 s_i 不同，adversary 可能同时看到其他客户端的密文。
  - 未证明 PRPG 生成的 a(t) 与均匀随机 a(t) 不可区分（ESAFL 明确处理了这一点）。
- **与 ESAFL 对比**：ESAFL Theorem 1 的分布定义包含 (B, a_0, a^t, c_i^t)，并先说明 a^t 由 PRPG 生成与均匀随机不可区分，再说明 RLWE 样本与均匀随机不可区分，最后得出整个分布与均匀分布不可区分。
- **修改建议**：参照 ESAFL，写出完整分布：
  - D = {(B, a_0, a(t), ct_{i,j}^{(t)})}；
  - 先证 a(t) ← PRPG(B,t) 与 U(R_q) 不可区分；
  - 再证 (a(t), a(t)s_i + p~e) 与 U(R_q^2) 不可区分（dRLWE）；
  - 最后说明加 m_b 后仍与均匀不可区分。

M3.6 未分析 PRPG 种子 B 的安全分发

- **位置**：Algorithm 1 第 3 行；第 IV-B 节。
- **问题描述**：所有客户端和 Server 共享 PRPG 种子 B，用于本地生成 a(t)。若 B 泄露给 adversary，则 a(t) 不再随机，RLWE 假设可能被破坏。论文未说明 B 如何安全分发，也未在安全分析中将其纳入。
- **修改建议**：
  1. 在威胁模型中说明 B 通过安全信道由 KGC 分发，且 B 对所有参与方（包括 Server）已知。
  2. 若 Server 知道 B，则 a(t) 对 Server 不是随机的，因此 Server 的视图分析不能依赖 a(t) 的伪随机性，而应依赖 s_i 和 e_{i,j}^{(t)} 的秘密性。需在 Theorem 2 中明确这一点。

M3.7 未处理跨轮残差与预取的联合隐私泄露

- **位置**：第 IV-C 节（残差更新）；第 IV-D 节（ECP）。
- **问题描述**：
  - ESP 维护本地残差 r_i(t)，并在多轮中累积未发送梯度。
  - ECP 允许客户端在 R 轮内预取聚合密文。
  - 客户端在同步时获得的是 R 轮聚合结果，可能结合自己历史贡献推断其他客户端在 R 轮内的累计更新。
  - 论文未分析这种时序聚合是否放大隐私泄露。

- **修改建议**：在安全分析中增加对时序/累积攻击的讨论，或明确声明安全保证仅限于单轮语义安全，不保证长期推断安全。

五、与 ESAFL 方案分析的对比问题

M4.1 未正确引用 ESAFL 的安全定理

- **位置**：第 V 节；参考文献 [33]。
- **问题描述**：论文在方案设计中参考了 ESAFL 的多密钥 RLWE 加密和一步解密，但在安全分析中未明确引用 ESAFL Theorem 1–5 的结论，也未说明哪些部分直接继承、哪些部分因引入稀疏化/预取而需要重新证明。
- **修改建议**：在安全分析开头增加一段“Relation to ESAFL Security Analysis”，明确：
  - Theorem 1（IND-CPA）继承自 ESAFL Theorem 1，并因 PRPG/多密钥设置做适应性修改；
  - Theorem 2/5 关于 multi-round privacy 与 ESAFL Theorem 2 的关系；
  - ESP 的投票掩码和 ECP 的预取队列是 ESAFL 没有的新组件，因此需要新的安全论证。

M4.2 将 ESAFL 的 cross-silo 分析直接套用到 cross-device 存在场景失配

- **位置**：全文；特别是实验与威胁模型。
- **问题描述**：
  - ESAFL 面向 cross-silo，客户端数量少、资源丰富、通常全参与、可假设可信 AS。
  - ECPFL 面向 cross-device，客户端数量大、部分参与、dropout 频繁、KGC 强信任。
  - ESAFL 不假设安全信道，所有通信走公共信道；ECPFL 假设 KGC-Client 安全信道，KGC 还需持续参与。
  - 论文未充分讨论这些差异对安全性的影响。
- **修改建议**：在威胁模型或 Related Work 中明确说明从 ESAFL 的 cross-silo/全参与到 ECPFL 的 cross-device/部分参与的迁移挑战，并解释为何 KGC 持续生成补偿密文在 cross-device 下仍然合理（或给出替代方案）。

M4.3 对 ESAFL “无需安全信道”优势的削弱

- **位置**：第 IV-B 节；Algorithm 1 第 3 行。
- **问题描述**：ESAFL 的一个重要卖点是无需客户端与云之间的安全信道即可保护训练结果。ECPFL 却假设 KGC 通过安全信道分发密钥和种子 B，且 KGC 与 Server 之间存在未明确定义的交互以生成补偿密文。这削弱了与 ESAFL 对比时的隐私优势。
- **修改建议**：
  1. 明确 KGC-Client 安全信道的必要性，并给出实现方式（如 TLS、密钥封装等）。

2. 讨论是否能去掉 KGC 与 Server 之间的交互，例如让 Server 自行生成补偿密文（零密文）而不需要 KGC 参与每轮。

六、其他重要问题

M5.1 摘要与引言中的安全声明过强

- **位置**：摘要第 18–19 行、第 33 行；第 I 节第 86–91 行。
- **问题描述**：摘要称“strictly preserving IND-CPA security”，引言称“rigorous security proofs establishing semantic security”。但 IND-CPA 仅保证单个密文在被动选择明文攻击下的不可区分性，不能保证聚合安全、预取安全、合谋安全或投票掩码隐私。论文后文实际证明的是更弱的性质。
- **修改建议**：将摘要和引言中的表述弱化为“provides IND-CPA security for individual ciphertexts and aggregation-result secrecy against a semi-honest server, with collusion resistance up to N-2 clients”，避免过度承诺。

M5.2 “IND-CPA”与“semantic security”混用

- **位置**：第 IV-B 节第 2）小节；第 V 节。
- **问题描述**：论文将 IND-CPA 作为最高安全目标，但 IND-CPA 对于聚合协议而言并不充分。一个聚合协议的安全通常需要更丰富的定义（如 semantic security of aggregation、simulation-based security）。
- **修改建议**：
  1. 明确 IND-CPA 适用于加密原语；
  2. 对聚合、预取、合谋等分别使用适合的安全定义，或至少说明这些是在 IND-CPA 基础上的推论。

M5.3 对 KGC “从不接收聚合模型更新”的声明与算法不一致

- **位置**：第 IV-B 节，第 6 页，第 492–496 行。
- **问题描述**：论文称 KGC “never receives, requests, or accesses any aggregated model updates”。但 KGC 需要生成补偿密文 ct_{k,j}^{(t)}，其形式为 [a(t) • s_k + p~ • e_{k,j}^{(t)} + 0]_q，这不需要聚合模型。然而，如果 KGC 要知道哪些 pack 需要补偿（即 K(t)），它必须从某处获得 K(t)；而 K(t) 由 Server 广播，可能隐含聚合信息。论文未说明 KGC 是否接收 K(t)。
- **修改建议**：明确 KGC 是否需要 K(t)、S(t) 等元数据，并据此修正“never receives… any aggregated model updates”的绝对表述。

M5.4 实验设置与安全假设不一致

- **位置**：第 VI-A 节。
- **问题描述**：实验使用 TenSEAL 或 xMK-CKKS 实现，但论文方案描述使用自定义多密钥 AHE（类似 ESAFL 的 ESHE）。TenSEAL 是单密钥 CKKS 库，xMK-CKKS 是多密钥库但不一定支持论文中的 PRPG/补偿密文机制。实验实现细节与安全假设之间可能存在 gap。
- **修改建议**：在实验设置中详细说明：
  1. 使用的具体库版本；
  2. 多密钥生成、PRPG、补偿密文是如何实现的；
  3. 是否满足论文中的安全假设（如 KGC 持钥、安全信道）。

七、修改优先级建议

优先级	问题编号	问题概述
高	M3.1	统一合谋抵抗术语，修正 (N-1)-resilience 与 (N-2)-collusion 的矛盾
高	M3.2	重写 Theorem 5，删除不成立的 one-time pad 论证
高	M3.3	修正 Theorem 4 关于 dropout 隐私的结论，区分 Server 与外部窃听者
高	M2.2 / M2.3	承认投票掩码明文泄露，调整安全目标
高	M1.2	明确 KGC 掌握全部私钥并持续参与的强信任假设
中	M1.1	删除“hybrid threat model”不当表述
中	M1.3	明确 KGC-Server 信道假设与交互
中	M3.5	完善 IND-CPA 证明，加入 PRPG 与多密钥形式化
中	M3.6	分析 PRPG 种子 B 的泄露风险
中	M4.1	明确引用并区分 ESAFL 安全定理
中	M4.2 / M4.3	讨论 cross-device 迁移与 KGC 安全信道假设
低	M5.1 / M5.2	弱化摘要/引言中的安全声明
低	M5.4	补充实验实现细节

八、结论

ECPFL 在通信效率优化上具有创新性，但当前版本在威胁模型、安全目标与安全性分析的衔接上存在多处需要修正的问题。核心建议是：

1. **规范威胁模型术语**：使用“semi-honest / honest-but-curious”而非“hybrid”；明确 KGC 的强权限与信任边界。

2. **对齐安全目标与敌手能力**：承认投票掩码、客户端选择等明文泄露；将 dropout 隐私目标重新定位到外部窃听者。
3. **修正安全证明**：particularly Theorem 3/4/5；避免 (N-1)/(N-2) 混淆、不成立的 one-time pad 论证、以及 Server 已知 dropout 状态却声称保护 dropout 隐私的矛盾。
4. **加强与 ESAFL 的对比**：明确继承 ESAFL 的哪些结论，并解释 cross-device/部分参与/KGC 补偿带来的新假设和新建证明需求。

完成以上修改后，论文的安全论证将更严谨，也更符合 IEEE/密码学社区的规范要求。